Fundamentals of Cybersecurity

Mohammad Hosseini

Faculty of Computer Science and Engineering
Shahid Beheshti University

Network

Network security threats



Overview

- In this chapter we focus on **remote networks**, where the user has little if any expectation of control, and thus the security risks are great.
- Three basic threat types we introduce
  - interception, modification, and interruption
- We presents important ways to **counter threats** to networking.

Security threats in networks

- Interception: unauthorized viewing
- Modification: unauthorized change
- Interruption: preventing authorized access

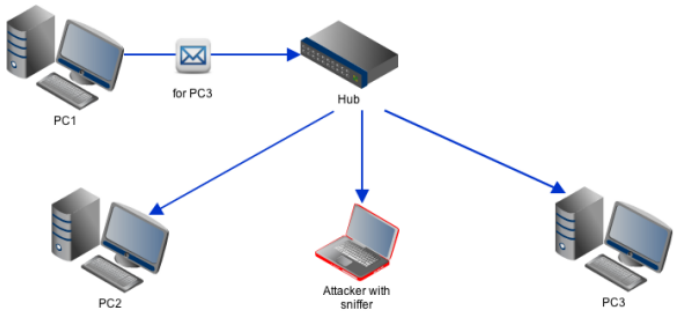
Interception: eavesdropping and wiretapping

- When data items leave a protected environment, people along the way can view or intercept the data.
- Signal interception is a serious potential network vulnerability.
- Data communications travel either on an **actual wire** or **wirelessly**, both of which are vulnerable, with varying degrees of ease of attack.

Cable

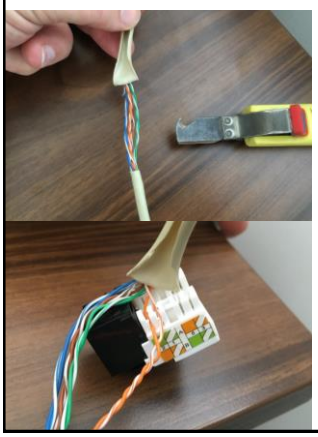


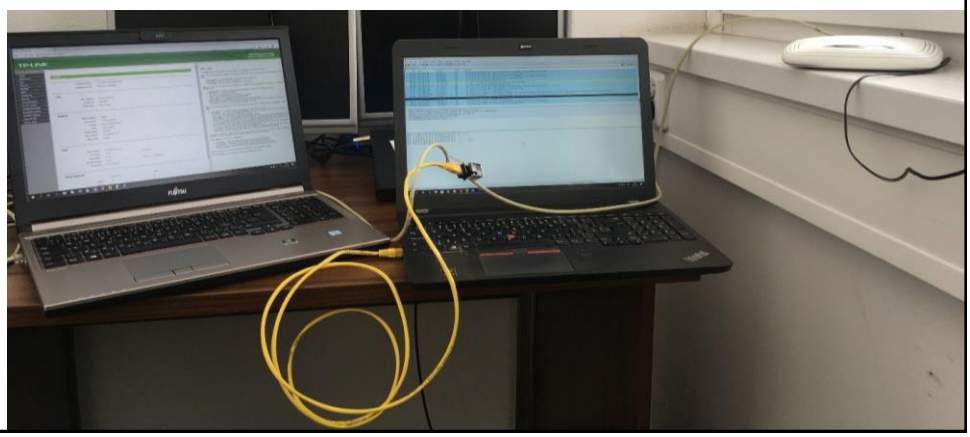
- The simplest network connector is a wire called an Ethernet cable
- Packet sniffer: a device that retrieves all packets on its LAN.
  - Alternatively, an interface card can be reprogrammed to have the supposedly unique address of another existing card on the LAN.



Cable

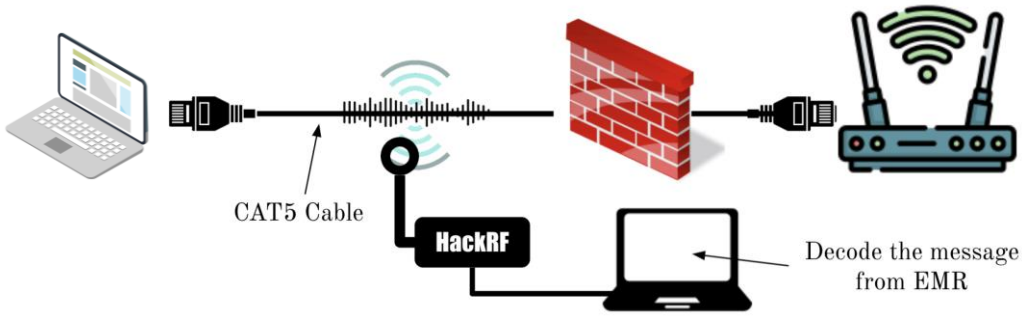
- Cable Splicing: an attacker can receive a copy of all signals along a cable by severing it and splicing in a secondary cable.
  - Alternatively, an attacker might carefully expose some of the conductor and connect to it.





Cable

- Radiation: wires emit radiation.
  - By a process called **inductance** an intruder can tap a wire and read radiated signals without making physical contact with it.
  - The intruder puts an antenna close to the cable and picks up the electromagnetic radiation of the signals passing through the wire.



Optical fiber

- Optical fiber carries light energy, not electricity.
- Splicing an optical fiber is not easy, and it can be easily detected due to the change in the transmitted energy.
- Light does not create a magnetic field as electricity does.
  - An inductive tap is impossible on an optical fiber cable.



Wireless

- Wireless signals are transmitted through the air, making them inherently more vulnerable to interception.
- The signal is so exposed.
- For computer security, the most important form of wireless communication is **WiFi**.
- What about satellite communication?



Everything is potentially exposed to interception

- From a security standpoint, you should assume that all communication links between network nodes can be broken.
- Moreover, users generally have little control over the routing of a signal.
- For this reason, network users employ encryption to protect the confidentiality of their communications.

Modification: data corruption

- The threat is that a communication will be changed during transmission.
  - Modifying data en route.
  - Crafting new content (insertion)
  - Repeating a previous communication (replay)

Data corruption

- Communications media are known to be vulnerable to data corruption.
  - Communications protocols include features to check for and correct, at least some, errors in transmission.
  - TCP/IP has extensive features to ensure that the receiver gets a complete, correct, and well-ordered data stream, despite any errors during transmission.
    - Are these mechanisms sufficient to address data corruption caused by a malicious attack?

Sequencing attack

- A sequencing attack involves permuting the order of data.
  - E.g., the second packet sent arrives at the receiver before the first packet.
- Sequencing errors are actually quite common in network traffic.
- Network protocols such as the TCP suite ensure the proper ordering of traffic.
  - However, application programs do not always detect or correct sequencing problems within the data stream.

Substitution attack

- Substitution attack: the replacement of one piece of a data stream with another.
  - A malicious attacker can perform a substitution attack by splicing a piece from one communication into another.
  - Countermeasures:
    - encryption, covering the entire message (making it difficult for the attacker to see which section to substitute)
    - creating an integrity check (making modification more evident).
- Insertion attack: new data values are inserted into a stream (almost a form of substitution)
  - An attacker does not even need to break encryption to insert data as long as the attacker knows precisely where to slip in the already encrypted data.

Replay attack

- Replay attack: an attacker intercepts a valid data transmission and retransmits it at a later time to deceive the recipient into performing unauthorized actions.
  - E.g., financial transactions
- The interceptor need not know the content or format of a transmission
- Replay attacks are often countered with a sequencing number.
  - Each recipient keeps the last message number received and checks each incoming message to ensure that its number is greater than the previous message received.

Physical replay

- Physical replay attack: a specific type of replay attack that occurs in systems involving physical signals or devices.
  - An attacker captures and replays physical signals (such as radio frequencies, images, or other sensory inputs) to deceive a system.



  - biometric authentication

Interruption: loss of service

- The final class of network attacks we consider involves **availability**, the third leg of the C-I-A triad.
- Networks, and especially the Internet, have solidly assured service.
  - From the earliest designs for the internet, redundancy and fault tolerance were important characteristics, and the robustness remains.
- Unlike confidentiality and integrity failures, however, denial of service is not binary.
  - Service capacity can be reduced
- E.g., bad information that poison the routing tables of routers and make a domain unreachable.

Port scanning

- The problem for an attacker is to know which attacks to employ on which machines.
  - Machines in a network
  - Network topology
  - Services running on a machine
- An easy way to gather network information is to use a port scanner.
  - A program that, for a particular IP address, reports which ports respond to queries and which of several known vulnerabilities seem to be present.
  - E.g., Nmap, netcat



Port scanning results

- Scanning is often used as a first step in an attack.

```
CL:   telnet incoming.server.net 110
SV:   +OK Messaging Multiplexor (Sun Java(tm) System Messaging Server
      6.2-6.01 (built Apr  3 2006))
      <4d3897ff.11ec04f8@vms108.mailsrvcs.net>
CL:   user v1
SV:   +OK password required for user v1@server.net
CL:   pass p1
SV:   -ERR [AUTH] Authentication failed
CL:   quit
SV:   +OK goodbye
```

Port scanning results

- A scanner such as Nmap probes a range of ports, testing to see what services respond.

```
Nmap scan report
192.168.1.1 / somehost.com (online) ping results
address: 192.168.1.1 (ipv4)
hostnames: somehost.com (user)
The 83 ports scanned but not shown below are in state: closed
Port      State     Service Reason      Product  Version  Extra info
21   tcp  open      ftp     syn-ack     ProFTPD  1.3.1
22   tcp  filtered  ssh     no-response
25   tcp  filtered  smtp    no-response
80   tcp  open      http    syn-ack     Apache   8.2.3    (CentOS)
106  tcp  open      pop3pw  syn-ack     poppassd
110  tcp  open      pop3    syn-ack     pop3d
111  tcp  filtered  rpcbind no-response
113  tcp  filtered  auth    no-response
143  tcp  open      imap    syn-ack     imapd    17.3
443  tcp  open      http    syn-ack     Apache   8.2.3    (CentOS)
465  tcp  open      unknown syn-ack
646  tcp  filtered  ldp     no-response
993  tcp  open      imap    syn-ack     imapd    17.3
995  tcp  open              syn-ack
2049 tcp  filtered  nfs     no-response
3306 tcp  open      mysql   syn-ack     MySQL    5.0.45
8443 tcp  open      unknown syn-ack
34 sec. scanned
1 host(s) scanned
1 host(s) online
0 host(s) offline
```

Port scanning results

- Port scanning tells an attacker three things:
  - which standard ports or services are running and responding on the target system
  - what operating system is installed on the target system
  - what applications and versions of applications are present

Port scanning results

- Another thing an attacker can learn is connectivity.
  - Scanning an entire subnetwork (e.g., 192.168.*.*)

```
Nmap scan report for router (192.168.1.1)
Host is up (0.00s latency).
MAC Address: 00:11:22:33:44:55 (Brand 1)

Nmap scan report for computer (192.168.1.39)
Host is up (0.78s latency).
MAC Address: 00:22:33:44:55:66 (Brand 2)

Nmap scan report computer (192.168.1.43)
Host is up (0.010s latency).
MAC Address: 00:11:33:55:77:99 (Brand 3)

Nmap scan report for unknown device 192.168.1.44
Host is up (0.010s latency).
MAC Address: 00:12:34:56:78:9A (Brand 4)

Nmap scan report for computer (192.168.1.47)
Host is up.
```

Port scanning

- Network administrators or system owners also use these tools to explore their networks.
  - The tool will report which devices may be running out-of-date and vulnerable versions of software that should be upgraded or which ports are unnecessarily exposed and should be closed.
  - Administrators of large networks may use a scanner to document and review all the devices connected to the network (because new devices may be added to the network at any time).